

REGULATORY & COMPLIANCE

HIPAA Security Risk Analysis & Breach Response Kit

A plain worksheet for the risk analysis OCR cites most often, a safeguards checklist for a small practice, and a step-by-step plan for the day something goes wrong.

AUDIENCE

Psychologists · Psychiatrists

FORMAT

Worksheet + checklists

VERSION

1.0 · Sept 2026

TIME TO ADAPT

2 to 3 hours to complete

WHAT IT IS

A do-it-yourself security risk analysis for a solo or small practice, a checklist of safeguards that reflects what regulators and insurers expect, and a breach response plan you can follow under pressure.

USE IT WHEN

You have never completed a risk analysis, it is more than a year old, you are changing systems, or you had an incident or a near miss.

CUSTOMIZE FIRST

Your systems inventory (Part B), the people responsible, and your state's breach notice rules.

WHERE THE RULES STAND

HHS proposed a major overhaul of the HIPAA Security Rule in January 2025 (mandatory multi-factor authentication and encryption, a technology inventory, and more). As of the reports we reviewed in mid-2026 it had not been finalized and the target date had slipped to around mid-2027. The current rule remains fully in force, and a documented, up-to-date risk analysis is the item OCR cites most often in investigations. Building to the proposed standard now costs little and avoids a rush later.

Part A: What a risk analysis is

A risk analysis is a written, dated assessment of where electronic patient information lives, what could go wrong with it, how likely and how serious each problem would be, and what you are doing about it. It is not a one-off. Repeat it at least yearly and whenever you change systems, move offices, add staff or have an incident. Keep every version.

Part B: Step 1: Inventory every place patient information lives

Include the obvious systems and the ones people forget: phones, personal email, text messages, voicemail, cloud storage, scanned documents, backups, old laptops, telehealth platforms, billing tools, AI tools (PA-11) and paper that is scanned.

System or device	What patient data	Location or vendor	BAA signed?	Encrypted?	MFA on?	Owner
Example: EHR	Full clinical record	Cloud vendor [name]	Yes	Yes	Yes	Me
Example: office laptop	Local downloads, notes drafts	Office	n/a	Full-disk on	Password only	Me

Part C: Step 2: Threats and vulnerabilities

For each system above, ask what could happen. Common threats to a small practice are below. Tick those that apply and add your own.

- ☐ Phishing or a stolen password leading to email or EHR access.
- ☐ Ransomware or malware that locks or copies files.
- ☐ Lost or stolen laptop, phone or USB drive.
- ☐ Unpatched software or an old operating system.
- ☐ A vendor breach or a vendor with no signed business associate agreement.
- ☐ Patient data sent to the wrong person by email, fax, text or portal.
- ☐ Shared logins or shared devices in a home office.
- ☐ Family members or visitors seeing or hearing sessions or screens.
- ☐ A departing clinician or staff member who keeps access.
- ☐ Fire, flood or hardware failure with no tested backup.
- ☐ Staff or clinician curiosity or misuse of records.
- ☐ Use of personal accounts or unapproved apps or AI tools for patient information.

Part D: Step 3: Rate the risks and plan

For each threat, rate likelihood (low, medium, high) and impact (low, medium, high). Focus first on high-high combinations. Record what you already do, what is missing, who will fix it, and by when.

Risk	Likelihood	Impact	Safeguards in place	Gap and action	Owner and date
Example: stolen laptop exposes local files	Medium	High	Full-disk encryption, password	Add MFA, remove local downloads, enable remote wipe	Me, [date]

Risk	Likelihood	Impact	Safeguards in place	Gap and action	Owner and date

Completed by

Reviewed by

Date

Part E: Safeguards checklist

Administrative

- ☐ Named privacy and security officer (in a solo practice, you).
- ☐ Written policies on access, passwords, devices, remote work, email and texting, telehealth, and retention.
- ☐ HIPAA and security training for everyone who touches patient data, at hire and every year. Records kept.
- ☐ A sanction policy and a departure checklist that removes access on the last day.
- ☐ A contingency plan: data backup, disaster recovery and how you would see patients if the system failed.
- ☐ A current list of business associates with signed agreements (see below).

Physical

- ☐ Locked office, locked file storage for any paper, and screens that cannot be seen from outside.
- ☐ Home office: private room, no shared computer, and no family access to devices or accounts.
- ☐ Secure disposal of paper (cross-cut shredding) and of old devices (verified wipe or destruction).
- ☐ Device inventory, including phones and tablets used for clinical work.

Technical

- ☐ Unique login for each person. No shared accounts.
- ☐ Multi-factor authentication on the EHR, email, cloud storage and remote access.
- ☐ Full-disk encryption on every laptop, phone and portable drive. Automatic screen lock.
- ☐ Automatic updates for operating systems, browsers and apps. No unsupported systems.
- ☐ Backups that are encrypted, kept separately from the main system, and restored as a test at least once a year.
- ☐ Secure email or portal for patient communications. No patient details in ordinary text messages or personal email.
- ☐ Anti-malware and a firewall. Audit logging turned on in the EHR and reviewed.
- ☐ AI tools used only after vetting and with a signed BAA where they touch patient data (PA-11).

FREE HELP

The HHS Office for Civil Rights and ONC publish a free Security Risk Assessment Tool at healthit.gov, and NIST publishes guidance (SP 800-30 on risk assessment and SP 800-66 on the Security Rule). HHS's voluntary Cybersecurity Performance Goals list the highest-value controls for small practices.

Business associate agreement checklist

A vendor that creates, receives, maintains or transmits patient information for you is a business associate, even if it says it cannot see the data. That includes cloud storage, EHR, billing, telehealth, answering services, IT support, shredding, transcription and AI documentation tools.

- ☐ Signed agreement before any patient data goes to the vendor.
- ☐ Limits use and disclosure to what the contract and law allow, with no use of your patient data to train its own models without your consent.
- ☐ Requires safeguards, breach and security-incident reporting to you within a set number of days, and flow-down to its subcontractors.
- ☐ Lets you get access to, or return or destruction of, the data when the contract ends.
- ☐ Allows HHS access to its books and records, and requires compliance with the Security Rule.

Part F: If something goes wrong

The first 24 hours

1. **Contain.** Disconnect affected devices from the network. Change passwords and revoke access. Do not wipe or reformat anything, because the evidence matters.
2. **Write down what you know** and when you learned it. The discovery date starts several clocks.
3. **Call your cyber and liability insurers.** Policies often require prompt notice and may give you an incident-response team and a lawyer. Ask before you pay for anything.
4. **Call an attorney** experienced in health privacy. Use counsel to direct the investigation where advised.
5. **Involve your vendors.** Ask your EHR and IT vendors for logs and for their own incident findings.
6. **Do not pay a ransom or contact the attacker** until you have advice from counsel and law enforcement.
7. **Consider reporting** to the FBI, CISA or local law enforcement as counsel recommends.

Is it a breach?

An impermissible use or disclosure of unsecured patient information is presumed to be a breach unless you can show a low probability that the information was compromised. Assess four factors and document your reasoning:

Factor	Questions
1. Nature and extent of the information	What was involved? Diagnoses, notes, identifiers, financial details? How likely is it that someone could identify the patient?
2. Who used or received it	Was it another HIPAA-covered entity or a person with a duty to protect it, or an unknown party?
3. Whether it was actually acquired or viewed	Did someone open, copy or take it, or was there only an opportunity to?
4. How far you reduced the risk	Can you retrieve it or get written assurance that it was destroyed and not further used?

TWO RULES OF THUMB

Properly encrypted information, using methods HHS recognizes, is not “unsecured,” so lost encrypted devices usually do not trigger notice. Ransomware that encrypts patient information is treated by HHS as a presumptive breach unless you can show a low probability of compromise.

Who to notify, and when

Recipient	Deadline and content
Affected individuals	Without unreasonable delay and no later than 60 days after discovery, by first-class mail or email if the patient agreed. Describe what happened and when, what information was involved, what patients can do to protect themselves, what you are doing, and how to reach you. Use substitute notice if you lack current contact details.
HHS (fewer than 500 people)	Log the breach and report through the HHS portal within 60 days after the end of the calendar year in which it was discovered.
HHS (500 or more people)	At the same time as individual notice, and no later than 60 days after discovery. Media notice is also required when more than 500 residents of one state or jurisdiction are affected.
State authorities and others	Many states have their own breach laws with shorter deadlines and attorney general notice. Check your state, your insurer and any contract with a payer.
Law enforcement delay	If law enforcement says notice would impede an investigation, you may delay, but document the request.

Incident log (one entry per incident)

Date and time discovered	Date it began (if known)	Reported by
What happened		
Systems, data and number of patients involved		
Containment steps and dates		
Four-factor assessment and decision (breach or not, and why)		
Notifications made (who, when, how)	Fixes and follow-up date	

Patient notice (short template)

Dear [Patient first name], We are writing to tell you about an incident at [Practice name]. On [date] we discovered that [brief, factual description]. The information involved was [types of information]. We [describe what you did to contain it and to prevent it happening again]. We recommend that you [steps, for example, watch for unusual messages and monitor accounts]. We are sorry this happened and we are here to answer your questions at [phone and email]. You may also contact the U.S. Department of Health and Human Services at hhs.gov/ocr. Sincerely, [Name]

IN PSYALLIANCE

Members can share, in the World library, anonymized vendor comparisons (for example EHR, telehealth and AI scribe security answers). Never post patient information, incident details that could identify anyone, or credentials.

Sources and further reading

- HHS, HIPAA Security Rule, 45 CFR Part 164, Subpart C, and Guidance on Risk Analysis (hhs.gov/hipaa/for-professionals/security).
- HHS, Breach Notification Rule, 45 CFR 164.400 to 164.414, and the HHS ransomware fact sheet (hhs.gov/hipaa).
- HHS and ONC, Security Risk Assessment Tool (healthit.gov/topic/privacy-security-and-hipaa/security-risk-assessment-tool).
- HHS OCR, HIPAA Security Rule to Strengthen the Cybersecurity of Electronic Protected Health Information, Notice of Proposed Rulemaking, Jan. 6, 2025 (status: proposed; check for updates).
- NIST SP 800-30 (risk assessment) and SP 800-66 (implementing the HIPAA Security Rule) (csrc.nist.gov).

ABOUT THIS DOCUMENT

Prepared by PsyAlliance from publicly available professional and regulatory sources, reviewed against them as of September 2026. It is an educational template and practice aid. It is not legal, ethical, clinical or billing advice, and it does not create a professional relationship. Laws, licensing-board rules and payer requirements vary by state and change over time. Verify against your licensing board, professional association, payer contracts and, where the stakes warrant it, a qualified attorney before relying on it.

Provided to PsyAlliance members for adaptation to their own practice. Please do not resell or republish. Text in **[highlighted brackets]** is a placeholder for you to complete.